macOS 原生考试窗口 Hook 新方案验证报告

独立方案 · 原生 UI 保留 · 按捕获进程拦截 | 2026-11-01

本轮在外部取屏进程中处理画面，考试窗口继续使用原生 AppKit 控件。该方案不依赖上一轮视频图层保护，也不把原生界面改绘成受保护视频。

审阅结论

验证对象	当前结果	结论边界
自有捕获探针	11 种入口 / 范围组合形成有效对照	9 路主矩阵 281 张 PNG；另 2 路 CGDisplayStream 抽样 41 张 PNG。
ToDesk 5.2.3.0	真实远端三阶段人工验证通过	本机已安装 hook 的用户级 Session，实际命中 SCK 显示器捕获；没有接收端录屏逐帧证据。
UU 4.40.0	本轮启动方式未加载见证库	原版 GUI、Service 与 Server 未观察到见证日志或映射；没有 UU 遮蔽成功证据。
完整产品能力	尚未成立	未加载 hook 的独立进程仍可截图；失败时放行、几何变化、复杂输入与部署生命周期尚待完善。

如何阅读证据

“已加载动态库”“已命中接口”“代码执行遮蔽”“远端真的隐藏”是四个不同结论。本报告分别呈现本地像素检查、进程日志、用户远端观察及恢复记录，不把其中一项替代其他项。

报告包含两幅真实实验截图；它们都来自本地独立探针，不是 ToDesk 或 UU 接收端截图。远端结果依据用户当场反馈。

实验环境：Apple M4 / arm64，macOS 26.6.2（25G83）。用户时间按 Asia/Calcutta（IST，UTC+05:30）展示，原始 JSON 保留 UTC。完整资料位于独立目录 Hook 新方案_20261101，之前报告与源码保留。

01 方案机制与实现范围

原生考试窗口保持正常显示。动态库安装在被测捕获进程内：截取或连续取屏产生画面后，库复制图像缓冲，将考试窗口对应区域填黑，再交给原接收对象。其他公共内容继续显示。

步骤	实现	本轮证据
1. 原生目标	NSWindow + 可编辑 NSTextField / NSTextView；按钮、滚动区、下拉框。	nativeUI=true；共享状态 readOnly；captureProtectionEnabled=false。
2. 目标范围	目标写出 windowID、ownerPID、CoreGraphics bounds 配置。	只包含考试窗；独立公共窗口不在遮蔽范围内。
3. 进程内拦截	C 入口用 dyld interpose；SCK 方法用 Objective-C runtime 包装。	image_loaded、capture_call 和样本回调分别记录。
4. 复制与遮蔽	复制 CGImage、BGRA CVPixelBuffer 或 IOSurface；保留原输入。	目标单窗口输出为不透明黑图；桌面范围只覆盖目标矩形。
5. 输出与复核	转交原截图回调 / 流接收者，再核验实际输出。	公共 LIVE-TICK 变化用于排除冻结整个画面。

适用单位是捕获进程

库只影响实际加载它的进程。另一个未加载库的程序、已经存在而未受控的旧 Session，或未覆盖的捕获后端，仍可能获取普通考试窗口。第 7 页的独立截图直接验证了这一边界。

不会自动继承的能力

窗口外的中文输入法候选、右键菜单、系统弹窗和其他敏感窗口不自动纳入目标矩形。新原生 Demo 未实现自身录像编码，本轮没有完成客户端自录与回放验收，不能沿用上一版画布 Demo 的录像结论。

实现：Sources/CaptureHook/CaptureHook.m；目标：Sources/NativeExamDemo/main.swift。v1.2 库 SHA-256 为 ce5f744b…3202f04；完整值见第 11 页。

02 环境、签名与加载条件

项目	实测配置
主机与系统	Apple M4 / arm64；macOS 26.6.2，build 25G83；单内置显示器。
ToDesk	5.2.3.0，build 2943；成功捕获进程为 ToDesk_Session，UID 501。
UU 远程	4.40.0，build 621；分别验证原版 GUI、用户级 Service 及派生 Server 的见证库加载。
Hook 构建	arm64，最低部署 macOS 14；本地 ad-hoc 签名。
LoadWitness 构建	纯 C，最低部署 macOS 11，仅 libSystem 依赖；不安装 hook，不调用取屏。
本轮显示参数	1512×982 point；捕获图像 3024×1964 pixel，BGRA。
系统安全状态	SIP 保持 enabled；未修改系统文件、TCC 数据库，未重签原版远程应用。

原版组件的签名差异

组件组	Hardened Runtime	允许 DYLD 环境变量	关闭 Library Validation
ToDesk 已检查主要组件	有	true	true
UU GUI / Service / Daemon / Server	有	未声明	未声明

上述元数据提供加载条件线索，不等于注入已成功。目标进程自己的签名配置决定其运行时例外；给考试应用增加 entitlement，不能自动改变另一程序的限制。两组均未声明 get-task-allow。

静态导入表发现 ToDesk 和 UU libstreamer 含 SCK、CGDisplayStream 等候选路径；符号存在与框架已加载，都不能独立证明正在执行哪条取屏链。ToDesk 的真实活动路径由后续 Session 日志确认。

完整静态基线包含 34 个 Mach-O 的哈希、架构、限定捕获符号与所选 entitlement，见 research/target-audit.json。官方依据见第 12 页 R01–R04。

03 受控主矩阵：9 种路径、281 张图

目标是普通原生考试窗口；四组均使用新的独立 CaptureProbe。权限为已授权，目标在窗口列表中可枚举；没有通过 SCK filter 主动排除考试窗口。下表为秘密标记 OCR 命中数 / 实际 PNG 数。

捕获范围 / 入口	baseline	audit	block	recovery
CGWindowListCreateImage：窗口	1/1	1/1	0/1	1/1
CGWindowListCreateImage：桌面合成	1/1	1/1	0/1	1/1
CGDisplayCreateImage：显示器	1/1	1/1	0/1	1/1
SCScreenshotManager.captureImage：窗口	1/1	1/1	0/1	1/1
SCScreenshotManager.captureImage：显示器	1/1	1/1	0/1	1/1
SCScreenshotManager.captureImage(in:)：矩形	1/1	1/1	0/1	1/1
SCStream：窗口	22/22	22/22	0/22	22/22
SCStream：显示器	21/21	21/21	0/21	20/20
SCStream：应用	21/21	22/22	0/22	21/21

281 张图由 24 张单帧截图和 257 张连续流 PNG 构成；全部完成解码与 OCR，未出现缺图、保存数量不符、流错误或 OCR 错误。四组分别保存 70、71、71、69 张。

有效对照，而不是只观察黑屏

block 的窗口和目标矩形输出是可解码的不透明黑图。显示器流 21/21、应用流 22/22 仍检出公共标记；两条流分别观察到连续变化的 LIVE-TICK。baseline、audit 与 recovery 仍能读到秘密，排除了目标从未出现或捕获本身失效的解释。

“9 种路径”包括同一 API 的不同范围，不是 9 个不同系统调用。应用范围只测试连续流，未测试应用级单张截图。恢复组是未加载库的新进程，不是在存活进程内卸载库。

有效目录：artifacts/controlled-matrix-20261101T134227Z。执行时间 19:12:27–19:12:56 IST；每组约 7 秒，流请求约 10 fps，有限采样不等于覆盖每次物理刷新。

04 受控实验截图：四阶段对照

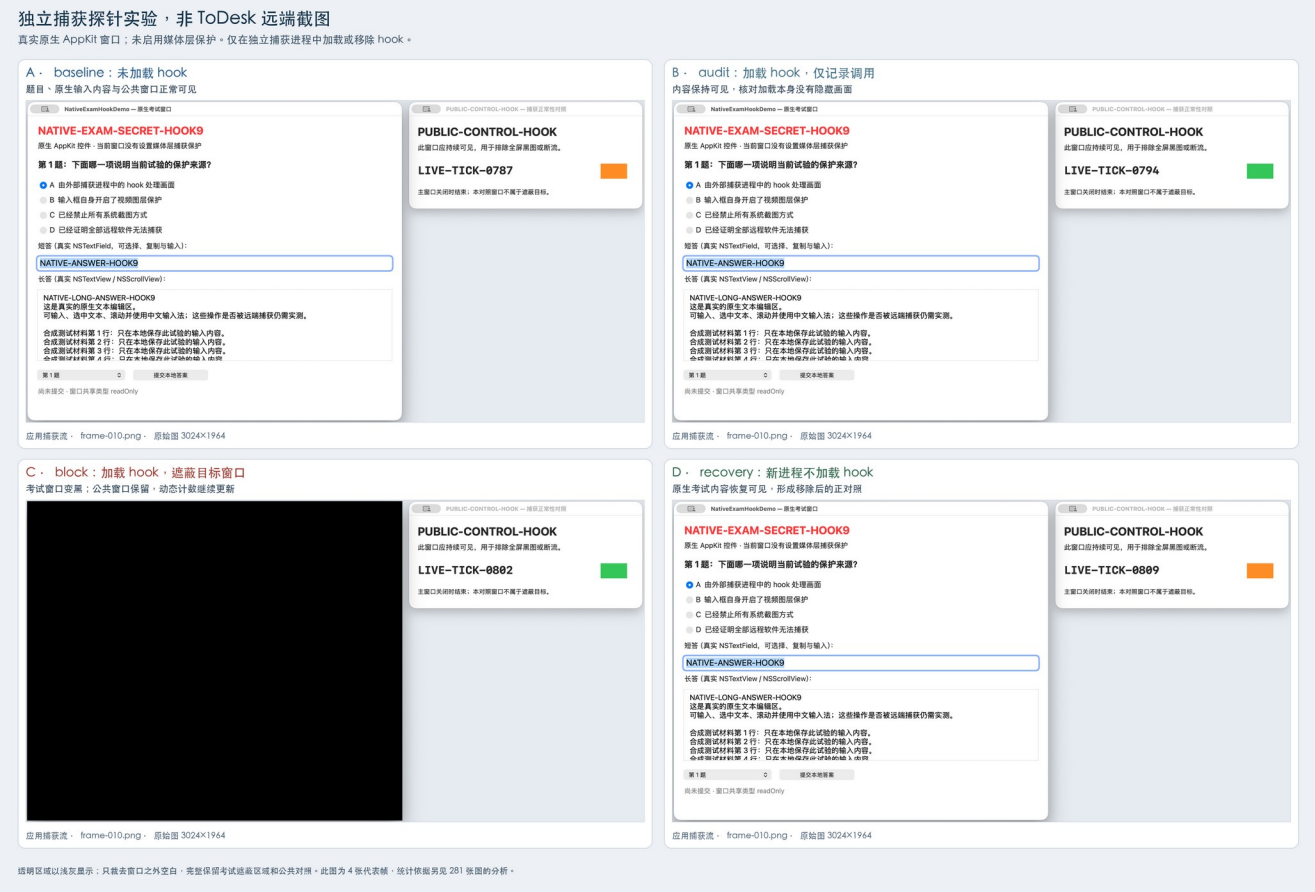


图 1 本地独立捕获探针的四组代表帧，非 ToDesk / UU 接收端截图。来源均为最终主矩阵的 sck-stream-application/frame-010.png；仅裁去测试窗口外空白，透明背景以浅灰显示，黑色来自原捕获结果。

阶段	代表帧中的可见现象	判定用途
baseline / audit	考试原生控件、题目和公共窗口均可见。	确认目标实际可被捕获，加载库本身未隐藏画面。
block	考试窗口为黑色，公共窗口仍可见。	展示处理后的像素效果；连续性以全部流帧及 LIVE-TICK 证据判定。
recovery	新捕获进程不加载库，题目恢复可见。	形成解除实验后的正对照。

四张图只用于直观审阅；结论依据全部 281 张输出图、权限/进程记录、捕获日志与 OCR。图中真实 NSTexField / NSTextView 的存在，不等于已覆盖中文 IME、菜单或完整原生编辑交互。

图源哈希、原始尺寸与裁剪边界：report-assets/controlled-comparison.sources.json。报告未重绘或补画原窗口内容。

05 ToDesk：真实远端验证成立

本机 ToDesk 5.2.3.0 已形成 audit → block → restore 三阶段人工对照。实际 hook 位于用户级 Session，命中 SCStream 显示器捕获；没有向 UID 0 的 ToDesk_Service 安装 hook。

阶段 / IST 时间	用户原始反馈	证据含义
audit 19:20:28	两个窗口内容都能看到，LIVE-TICK 在变化。	远端可见考试内容，公共对照持续变化。
block 19:25:01	考试区域已隐藏，右侧计数仍在变化。	目标区域隐藏，远程连接没有整体冻结。
restore 19:29:18	考试内容已恢复可见，右侧计数正常变化。	恢复原任务、重新建立正常会话后，题目恢复。

从库加载推进到实际调用

audit 的实际捕获进程为 Session PID 19317；block 成功轮次为 PID 32469。均记录 SCStream.init、addStreamOutput、startCapture 成功、持续画面回调和 stopCapture。图像为 3024×1964 BGRA，覆盖 displayID 1。

日志项	audit	block
sck_stream_frame 日志条数	332	165
带 BGRA 图像的抽样记录	234	130
无 imageBuffer 的抽样记录	98	35
redacted 处理结果日志	不执行遮蔽	130
日志中的最大回调序号	19860	9840

日志只在首个回调和每 60 次回调记录一次。表中数量不是保存的视频帧数，也不是全部帧的像素检查；无 imageBuffer 的回调不计为遮蔽成功。本轮没有录制远端接收画面，因此人工观察不能排除观察间隙中的短暂漏帧。

证据：todesk-audit-20261101T134436Z、todesk-block-20261101T135207Z 中的 hook.jsonl 与三份 human-observation / human-recovery-observation 记录。

06 范围反证：未装 hook 的进程仍可截图

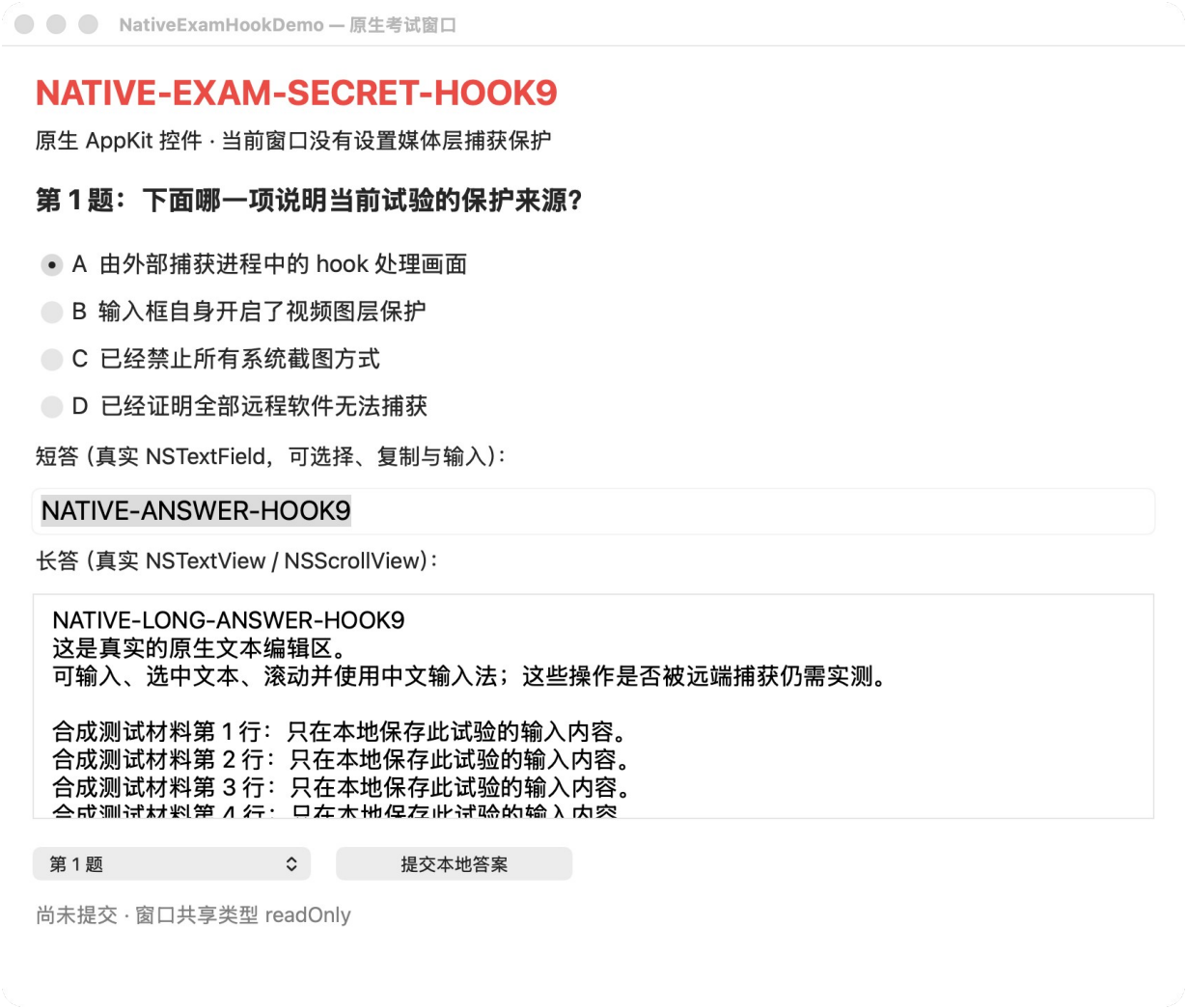


图 2 ToDesk block 期间，本地另一个未加载 hook 的独立探针截取同一原生考试窗口。此图不是 ToDesk 接收端截图。原图 1700×1444，题目及输入内容可读，OCR secretDetected=true；捕获返回码 0。

这张图与上一页远端隐藏结果并不矛盾：原生窗口仍产生正常、可捕获的像素，改变的是加载了 hook 的捕获进程所交付的图像。独立进程没有加载库，所以仍能取得题目。

因此，当前结果不能写成“macOS 已对该窗口实施全局禁止捕获”。每个新软件、另一个实例、辅助进程、用户会话或后端，都要单独确认库加载和实际拦截覆盖。

证据目录：artifacts/todesk-block-20261101T135207Z/independent-unhooked-check；scope-check.json、report.json、ocr.jsonl 可追溯原图。

07 UU：最小加载实验与当前边界

为区分加载障碍和 CaptureHook 代码问题，本轮另做纯 C LoadWitness：构造器只写 image_loaded 日志，仅依赖 libSystem，不链接 AppKit/SCK、不安装任何 hook。自有宿主的加载、无日志路径及特殊路径转义等五项自测全部通过。

试验对象	新进程 / 派生进程	结果
UU 原版 GUI 启动	PID 56546	没有 image_loaded；vmmap 返回 0，未检出见证库映射。
UU 用户级 Service 启动任务	PID 72311	没有 image_loaded；vmmap 返回 0，未检出见证库映射。
该 Service 派生 Server	PID 72316	没有 image_loaded；vmmap 返回 0，未检出见证库映射。

能够确认的结论

在本机原版 UU 4.40.0 的这些具体启动方式中，最小外部库未观察到加载，因此没有继续声称 CaptureHook 已进入实际取屏链，更没有 UU 远端遮蔽成功结论。GUI 文件 SHA-256 在实验前后保持一致。

UU 的加固签名未声明允许 DYLD 环境变量和关闭 Library Validation，与上述加载结果一致。但仅凭这些证据，不能将失败精确归因于某个内部判断，也不能外推为所有可能加载方式都不可行。

恢复与活动路径

UU 恢复状态及其实际活动取屏路径，等待本轮最终验证记录纳入。

必须保持的证据区分

静态 libstreamer 导入 SCStream / CGDisplayStream，只能作为候选线索；动态采样若命中某后端，只证明当时活动路径；见证库未加载则不能声称已对该路径安装拦截。没有日志也需结合新 PID、日志路径、vmmap 成功与签名条件共同解释。

GUI：artifacts/uu-load-witness-20261101T140503Z/result.json；Service / Server：artifacts/uu-service-witness-20261101T141332Z/load-check.json；自有加载对照：load-witness-selftest-20261101T135819Z。

08 补测：两种 CGDisplayStream 入口

本节是在自有独立探针里补测两种历史连续捕获创建入口，未据此认定 ToDesk 或 UU 的实际远端 CGDisplayStream 路径已经被拦截。目标静止、单屏、BGRA，接收者消费完整 IOSurface。

入口 / 阶段	完整回调	PNG	秘密 / PNG	公共 / PNG	LIVE-TICK
DispatchQueue / baseline	20	5	5/5	5/5	2517–2519
DispatchQueue / audit	20	5	5/5	5/5	2520–2522
DispatchQueue / block	20	5	0/5	5/5	2522–2524
DispatchQueue / recovery	20	5	5/5	5/5	2525–2527
RunLoop / baseline	20	5	5/5	5/5	2528–2530
RunLoop / audit	20	5	5/5	5/5	2531–2532
RunLoop / block	21	6	0/6	6/6	2533–2535
RunLoop / recovery	20	5	5/5	5/5	2536–2538

共 161 个完整帧回调，保存并检查 41 张 PNG；这是抽样图像检查，不是对全部 161 次回调逐帧 OCR。两种入口都形成 baseline / audit 可读、block 秘密消失且公共动态保留、recovery 恢复的对照链。

补测没有消除的限制

CGDisplayStream block 分支复制 IOSurface 后遮蔽，不原地修改系统共享缓冲。它保留原 dirty-region metadata，没有把遮蔽区域加入脏区；只消费 dirty region 的客户端，以及目标移动之后的缓存一致性尚未验证。

含 sourceRect / destinationRect 裁剪属性、非 BGRA、平面格式或无法映射的画面会明确走 passthrough。API 使用历史导出符号完成兼容实验，不能据此认定其为当前新产品推荐部署接口。

9 种主矩阵范围 / 入口 + 本节 2 种创建入口 = 11 种实验组合，不是 11 个不同系统调用。281 张主矩阵 PNG 与 41 张补测 PNG 分别统计，合计 322 张有效分析图，不混入失败轮次。

证据目录：artifacts/display-stream-matrix-20261101T141122Z；summary.json、summary.md、各 case 的报告与 OCR 可复核。

09 部署、恢复与产品化门槛

成功的 ToDesk 实验临时替换当前用户 GUI 域的 Session Proxy 启动定义，让新派生 Session 继承本轮环境。修改的是项目内保存的实验副本及当前会话注册状态，原 /Library plist 和 /Applications 可执行文件字节保持不变。

检查项	本轮状态 / 需要保留的边界
ToDesk 原任务恢复	来源恢复为 /Library/LaunchAgents/com.youqu.todesk.session.plist；新的 Proxy / Session 与用户远端恢复确认相互印证。
原始文件一致性	原 plist 哈希与基线一致；GUI、Service、Proxy、Session 四个关键可执行文件 SHA-256 一致。哈希检查不冒充额外完整 codesign 验证。
旧子进程	恢复 job 不会自动卸载存活旧 Session 中的库；需要检查旧 PID 与会话重建，不能只看 bootstrap 返回码。
启动竞争	第一次 block bootstrap 返回 5，来源检查发现原 job 已重新注册；脚本自动回滚。具体重注册者未定位。
UU 原任务恢复	等待最终恢复核验记录，不能仅凭一次启动返回值认定所有实验环境已撤销。

当前 block 仍是 fail-open PoC

配置无效或禁用、范围未知、格式不支持、裁剪未实现、分配或锁定失败时，库可能把原画面继续传给调用方，并记录原因。因此它还没有实现“出错时阻止敏感输出”的产品策略。

后续必须单独验收

必须覆盖软件更新、服务重启、旧流、新会话、并发捕获、窗口移动与调整大小、跨屏/旋转/缩放、最小化、睡眠唤醒，以及外部菜单和 IME。还需测量真实远端 CPU、内存、端到端延迟与丢帧，并取得接收端视频做逐帧复核。

当前结果支持固定环境下的独立新方案原型；不支持“任意考生设备、任意远程软件和任意捕获进程已统一受控”的产品声明。

10 复现入口与证据清单

复核应先分析已有证据，再按需要执行新实验。真实远程软件的启动任务测试会改变当前远程会话，必须在可恢复条件下执行；不要把旧 PID 或另一条会话误认为本轮受测进程。

资料	项目内位置 / 用途
原生目标	Sources/NativeExamDemo/；真实控件和 hook-config.json 状态协议。
捕获拦截库	Sources/CaptureHook/；v1.2 源码、构建方式和 fail-open 条件。
最小加载见证	Sources/LoadWitness/；纯 C 构造器与五项自有宿主对照。
主矩阵	artifacts/controlled-matrix-20261101T134227Z；281 图、权限、PID、输出数量与 OCR。
CGDisplayStream 补测	artifacts/display-stream-matrix-20261101T141122Z；161 完整回调、41 图抽样。
ToDesk 真实远端	todesk-audit-20261101T134436Z、todesk-block-20261101T135207Z；日志、人工确认和恢复记录。
UU 加载限制	uu-load-witness-20261101T140503Z、uu-service-witness-20261101T141332Z；新 PID、见证日志及映射核验。
图源与审计	report-assets/controlled-comparison.sources.json；research/target-audit.json；各轮 manifest / summary。

仅分析已有图像的命令

```
python3 scripts/analyze-hook-matrix.py \
  artifacts/controlled-matrix-20261101T134227Z
python3 scripts/analyze-display-stream-matrix.py \
  artifacts/display-stream-matrix-20261101T141122Z
```

有效库标识

build/libCaptureHook-v1.2.dylib

```
SHA-256
ce5f744bd17fb25b617f9a70eb969dcedcb2fe296e9b0c3424f647a6f3202f04
```

旧版默认库与失败轮次均留档；复现前应核对所选库版本及哈希。文件存在、属性设置成功、hook 安装成功均不替代像素结果。

11 失败记录、证据等级与官方依据

保留记录	不能计作成功的原因
主矩阵 133231Z	旧库用 RTLD_NEXT 解析原 C 符号后发生重入，audit / block 返回 -11；v1.2 改为 interposing image 内原符号绑定。
主矩阵 133652Z	参数组合不兼容，四组返回 64，0 图；捕获尚未发生。
主矩阵 133946Z	目标不在可见窗口枚举中，部分路径跳过；目标可见性不确定，整轮降级。
主矩阵 133510Z	显示器对照被其他窗口遮挡；局部有效结果不扩大为整轮所有范围通过。
首次 ToDesk block	bootstrap 返回 5 并检测到原任务重新注册；自动恢复，未计为遮蔽成功。

已验证：有效探针像素结果、ToDesk 具体 Session 的实际 SCK 调用与三阶段远端人工反馈、UU 本轮未加载见证库。未验证：完整原生交互、所有后端、跨版本部署、自身录像产品链路、远端全部传输帧。推断：已声明的运行时例外有助于解释 ToDesk / UU 的加载差异，但不能替代具体进程实验。

Apple 官方依据

R01 Hardened Runtime 配置与应用自身的运行时例外

R02 Allow DYLD Environment Variables entitlement

R03 Disable Library Validation entitlement

R04 Debugging Tool entitlement 与 task-port 限制

R05 SCStream：内容过滤、输出接收与捕获生命周期

R06 SCScreenshotManager：单帧捕获入口

文档语义用于解释 API 与部署条件；本机效果以本报告指定的版本、进程、路径和实验数据为准。报告编制未关闭 SIP、重签原版应用或将某一成功样本提升为全路径防捕获保证。